

Vulnerability Assessment Report

Target Application: OWASP Juice Shop

Submitted in Partial Fulfilment of DHC Internship Program

Testing Date: May 22, 2026

Tester: Syeda Arooj Fatima ¹

DHC Intern ID : DHC-1161

Testing Type: Manual Testing + Tool Assisted (OWASP ZAP)

1. Executive Summary

OWASP Juice Shop was tested for common web vulnerabilities. Multiple critical and high-risk vulnerabilities were successfully identified, including **Cross-Site Scripting (XSS)**, **Broken Authentication**, and **Information Disclosure**. The application is intentionally vulnerable and serves as an excellent learning platform.

2. Vulnerabilities Found

#	Vulnerability	Severity	Status	Challenge Stars
1	Cross-Site Scripting (XSS)	High	Confirmed	1★
2	Broken Authentication (Admin Bypass)	High	Confirmed	2★
3	Access Log Disclosure	Medium	Confirmed	4★
4	Weak Password Storage	Medium	Suspected	-
5	Information Disclosure	Medium	Confirmed	-

3. Detailed Findings

A. Cross-Site Scripting (XSS)

- **Location:** Search functionality
- **Type:** Reflected XSS
- **Payload Used:**
- **Impact:** Attacker can execute arbitrary JavaScript in users' browsers.

B. Broken Authentication

- **Location:** Login page
- **Method:** SQL Injection bypass (admin'--)
- **Impact:** Unauthorized access to admin panel.

C. Access Log Disclosure

- **Location:** /support/logs

- **Impact:** Exposure of sensitive access logs and potential user information.

D. Weak Password Storage

- Observed weak/default passwords and possible weak hashing mechanism.

4. Areas of Improvement

1. Implement proper input validation and output encoding to prevent XSS.
2. Fix SQL Injection vulnerabilities in search and login functions.
3. Use strong password hashing (bcrypt with high cost or Argon2).
4. Disable directory listing and detailed error messages in production.
5. Implement proper authorization checks on sensitive endpoints.

5. Evidence / Screenshots

5.1 Overall Progress

Figure 1: Scoreboard

```
warn: "AI Debugging" challenge will not work as intended without access to http://localhost:11434/v1
info: Check https://howto-llm.owasp-juice.shop for instructions on how to set up and configure the LLM API
info: Server listening on port 3000
info: Restored 4-star accessLogDisclosureChallenge (Access Log)
info: Restored 1-star directoryListingChallenge (Confidential Document)
info: Restored 1-star errorHandlerChallenge (Error Handling)
info: Restored 1-star scoreBoardChallenge (Score Board)
Error: SQLITE_ERROR: near "%": syntax error
Error: SQLITE_ERROR: near "UNION": syntax error
info: Solved 2-star loginAdminChallenge (Login Admin)
info: Cheat score for tutorial loginAdminChallenge solved in 11min (expected ~2min) with hints allowed: 0
```

restart. Björn Kimminich (9 years ago) Ln 6, Col 13 Spaces: 2 UTF-8 CRLF {} JavaScript

5.2 Cross-Site Scripting (XSS)

Figure 2: XSS Payload in Search Bar

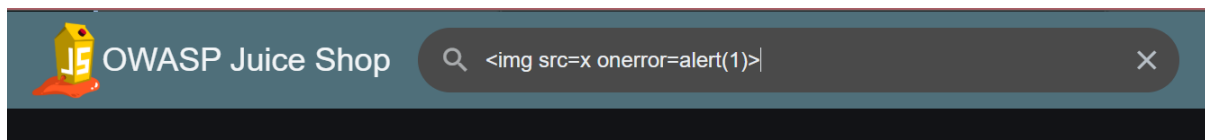
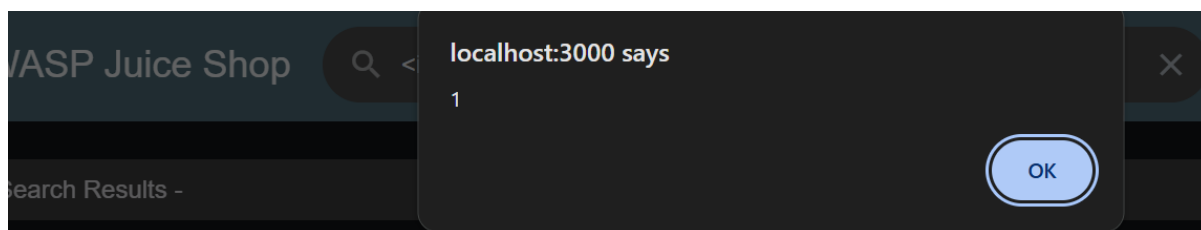


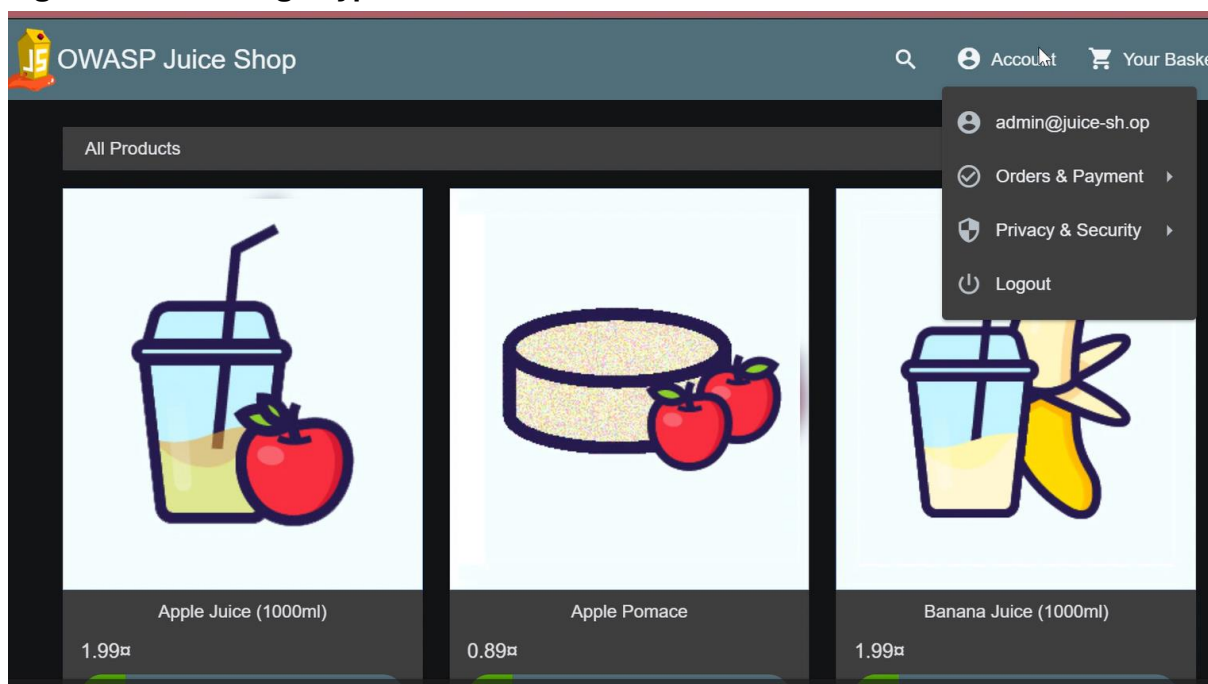
Figure 3: Successful XSS Popup



]

5.3 Broken Authentication

Figure 4: Admin Page Bypass



5.4 Access Log Disclosure

Figure 5: Downloaded Log File

```

::1 - - [21/May/2026:18:39:22 +0000] "GET /rest/user/whoami HTTP/1.1" 200 138 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:39:23 +0000] "GET /rest/basket/6 HTTP/1.1" 200 154 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:39:23 +0000] "GET /rest/products/search?q= HTTP/1.1" 304 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:39:23 +0000] "GET /api/Quantities/ HTTP/1.1" 304 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:41:50 +0000] "GET /rest/user/change-password?current=butterfly&new=juice&repeat=juice HTTP/1.1" 200 360 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:42:37 +0000] "GET /rest/products/search?q= HTTP/1.1" 304 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:42:37 +0000] "GET /api/Quantities/ HTTP/1.1" 304 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:24 +0000] "GET /rest/saveLoginIp HTTP/1.1" 401 12 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:24 +0000] "GET /rest/products/search?q= HTTP/1.1" 200 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:24 +0000] "GET /api/Quantities/ HTTP/1.1" 200 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:28 +0000] "GET /rest/admin/application-configuration HTTP/1.1" 304 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:54 +0000] "POST /rest/user/login HTTP/1.1" 401 26 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:54 +0000] "GET /rest/user/whoami?fields=email HTTP/1.1" 200 11 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:54 +0000] "GET /rest/user/whoami HTTP/1.1" 200 11 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:47:59 +0000] "GET /api/SecurityQuestions/ HTTP/1.1" 200 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:49:00 +0000] "POST /api/Users/ HTTP/1.1" 201 308 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:49:00 +0000] "POST /api/SecurityAnswers/ HTTP/1.1" 201 227 "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:49:01 +0000] "GET /rest/admin/application-configuration HTTP/1.1" 304 - "http://localhost:3000/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"
::1 - - [21/May/2026:18:50:38 +0000] "GET /favicon.ico HTTP/1.1" 200 - "http://localhost:3000/support/logs" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36"

```

5.5 Tool Usage (Optional)

Figure 7: OWASP ZAP Scan Results

The screenshot displays the OWASP ZAP (Zed Attack Proxy) interface during an automated scan. The top section, titled "Automated Scan", includes instructions and a "URL to attack" field set to "http://localhost:3000". Below this, there are checkboxes for "Use traditional spider" (checked) and "Use ajax spider" (set to "Always" with "Firefox" as the engine). The "Progress" bar indicates "Actively scanning (attacking) the URLs discovered by the spider(s)".

The bottom section shows the "Alerts" tab with a list of detected issues. The first alert is "Content Security Policy (CSP) Header Not Set (Systemic)", which is highlighted. The details for this alert are as follows:

- URL:** http://localhost:3000/sitemap.xml
- Risk:** Medium
- Confidence:** High
- Parameter:**
- Attack:**
- Evidence:**
- CWE ID:** 693
- WASC ID:** 15
- Source:** Passive (10038 - Content Security Policy (CSP) Header Not Set)
- Alert Reference:** 10038-1

6. Conclusion

The testing successfully demonstrated several real-world web application vulnerabilities. Fixing these issues (especially XSS and SQL Injection) should be high priority before deploying any similar application in production.